NEXUS SECURITY ADVISORS

HIPAA Security Rule & 405(d) Readiness Self-Check

Healthcare providers, health plans, and business associates handling ePHI

Maps the current HIPAA Security Rule (45 CFR Part 164, Subpart C) and the HHS 405(d) Health Industry Cybersecurity Practices (HICP). A proposed Security Rule update (Jan 2025) is not yet final; items marked 'Proposed rule' show where requirements are heading.

Organization: _____ Completed by: _____ Date: _____

☐	ID	Section	Requirement	Reference	Priority	Evidence
☐	HIPAA-01	Administrative Safeguards	Conduct an accurate, thorough risk analysis of risks to ePHI	45 CFR 164.308(a)(1)(ii)(A)	High	Current risk analysis report
☐	HIPAA-02	Administrative Safeguards	Implement risk management measures to reduce risks to reasonable levels	45 CFR 164.308(a)(1)(ii)(B)	High	Risk treatment plan with owners
☐	HIPAA-03	Administrative Safeguards	Designate a security official responsible for the security program	45 CFR 164.308(a)(2)	High	Appointment letter / job description
☐	HIPAA-04	Administrative Safeguards	Provide security awareness and training for all workforce members	45 CFR 164.308(a)(5)	Medium	Training records; phishing simulation results
☐	HIPAA-05	Administrative Safeguards	Maintain security incident procedures to identify, respond to, and document incidents	45 CFR 164.308(a)(6)	High	Incident response plan; incident log
☐	HIPAA-06	Administrative Safeguards	Maintain a contingency plan: data backup, disaster recovery, and emergency-mode operations	45 CFR 164.308(a)(7)	High	Backup reports; DR test results
☐	HIPAA-07	Administrative Safeguards	Execute business associate agreements with vendors that handle ePHI	45 CFR 164.308(b); 164.314(a)	High	BAA inventory
☐	HIPAA-08	Physical Safeguards	Limit physical access to facilities and systems containing ePHI	45 CFR 164.310(a)(1)	Medium	Facility access procedures
☐	HIPAA-09	Physical Safeguards	Control the receipt, removal, disposal, and reuse of devices and media	45 CFR 164.310(d)(1)	Medium	Device/media disposal records
☐	HIPAA-10	Technical Safeguards	Assign unique user IDs and implement access controls and automatic logoff	45 CFR 164.312(a)(1)	High	IAM configuration; access reviews
☐	HIPAA-11	Technical Safeguards	Encrypt ePHI at rest where reasonable and appropriate (required under the proposed rule)	45 CFR 164.312(a)(2)(iv); Proposed rule	High	Disk/database encryption evidence
☐	HIPAA-12	Technical Safeguards	Record and examine activity in systems containing ePHI (audit controls)	45 CFR 164.312(b)	High	Audit log configuration; review records

☐	ID	Section	Requirement	Reference	Priority	Evidence
☐	HIPAA-13	Technical Safeguards	Verify the identity of persons or entities seeking access; use MFA	45 CFR 164.312(d); Proposed rule	High	MFA coverage report
☐	HIPAA-14	Technical Safeguards	Protect ePHI in transit with encryption	45 CFR 164.312(e)(1)	High	TLS configuration; secure email settings
☐	HIPAA-15	Documentation	Keep written policies and procedures and retain documentation for six years	45 CFR 164.316(b)	Medium	Policy library with version history
☐	HIPAA-16	Proposed Rule Readiness	Maintain a written technology asset inventory and network map for systems touching ePHI	Proposed rule (Jan 2025)	Medium	Asset inventory; network map
☐	HIPAA-17	Proposed Rule Readiness	Run vulnerability scans at least every 6 months and penetration tests every 12 months	Proposed rule (Jan 2025)	Medium	Scan and pen test reports
☐	HIPAA-18	405(d) HICP	Email protection, endpoint protection, and access management (HICP practices 1–3)	HHS 405(d) HICP	High	Email filtering/DMARC; EDR coverage; IAM
☐	HIPAA-19	405(d) HICP	Asset, network, and vulnerability management, including network-connected medical devices	HHS 405(d) HICP	High	Inventory; segmentation; medical device list

Readiness self-check for general guidance only. Not legal advice and not a formal assessment or certification. Confirm requirements against official sources.